

STRIDE Threat Analysis — UWA Student Portal

Applied to the Data Flow Diagram (DFD) constructed for B27. Each row identifies a component or data flow, maps it to a STRIDE threat category, describes a specific threat instance, and proposes a concrete mitigation.

Component / Data Flow	STRIDE	Threat	Mitigation
Student (External Entity)	S — Spoofing	Attacker uses stolen credentials to impersonate a student and access the portal.	Multi-factor authentication (MFA) enforced at SSO login; account lockout after failed attempts.
Web Browser (Process)	S — Spoofing	A phishing site mimics the UWA portal login page to harvest credentials.	UWA SSO uses HTTPS with HSTS; students should verify the URL and SSL certificate before entering credentials.
UWA SSO / IdP (Process)	S — Spoofing	Attacker forges a SAML assertion to impersonate a legitimate user to the web server.	Web server validates SAML assertions using the IdP's public key certificate; invalid signatures are rejected.
Credentials Flow	T — Tampering	Man-in-the-middle intercepts and modifies credentials in transit if HTTPS is misconfigured.	HTTPS with TLS 1.2+ enforced on all connections; HSTS prevents downgrade to HTTP.
Portal Web Server (Process)	T — Tampering	SQL injection via unsanitised form input modifies database queries to alter or leak data.	Parameterised queries / prepared statements used for all DB interactions; input validation on all fields.
Student Database (Data Store)	T — Tampering	Unauthorised modification of grade or enrolment records by a privileged insider.	Role-based access control (RBAC) limits write access; all changes logged to an immutable audit trail.
Portal Web Server (Process)	R — Repudiation	A student denies submitting an enrolment change; no audit log exists to verify the action.	Server-side audit logging records all user actions with timestamp, user ID, and IP address.
Student (External Entity)	R — Repudiation	Student denies accessing a resource or changing account details.	Session logs tied to authenticated user ID; non-repudiation provided by SSO-issued JWT with timestamp.
Session Token (SSO Response)	I — Info Disclosure	JWT session token stored in browser localStorage is exposed via XSS attack.	Tokens stored in HttpOnly, Secure cookies only; Content Security Policy (CSP) headers prevent XSS exfiltration.
Student Database (Data Store)	I — Info Disclosure	Unencrypted sensitive data (grades, personal info) exposed if the database server is compromised.	Data encrypted at rest (AES-256); database server isolated in internal network with no direct internet access.
LMS / Blackboard API Flow	I — Info Disclosure	API key for LMS integration hardcoded in web server code and exposed via source code leak.	API keys stored as environment variables, never in source code; rotated regularly; repo scanned with TruffleHog.
UWA SSO / IdP (Process)	D — Denial of Service	SSO flooded with authentication requests during exam period, blocking all student logins.	Rate limiting and CAPTCHA on login endpoint; horizontal scaling and DDoS protection (e.g., Cloudflare) in place.
Portal Web Server (Process)	D — Denial of Service	Web server overwhelmed by a DDoS attack, making the portal unavailable to all students.	Load balancer with auto-scaling; rate limiting per IP; upstream DDoS mitigation service.

Component / Data Flow	STRIDE	Threat	Mitigation
Portal Web Server (Process)	E — Elevation of Priv.	IDOR vulnerability allows a student to modify another student's enrolment by changing a user ID parameter in a URL.	Server-side authorisation checks on every request ensure users can only access their own records; session ID never used as the sole access control.
UWA SSO / IdP (Process)	E — Elevation of Priv.	Attacker modifies a JWT token payload to claim an admin role, gaining elevated privileges.	Web server verifies JWT signature using the IdP's public key on every request; unsigned or invalid tokens are rejected.

STRIDE Key: S = Spoofing | T = Tampering | R = Repudiation | I = Information Disclosure | D = Denial of Service | E = Elevation of Privilege